

MA2006B Uso de álgebras modernas para seguridad y criptografía Gpo(601)

Gestor de Identidades 1.0 Casa Monarca

Integrantes del equipo 2

Nombre	Matrícula
Daniela Ortiz Blanco	A00840140
Fernanda Ojeda Tamayo	A01286528
Axel Gabriel Rocha Pérez	A01067854
Ian Roberto Rendón Berlanga	A01384161
Edgar Antonio Larios Rodríguez	A01722806

Profesores

Nombre
Alberto F. Martínez
Daniel Otero Fadul
Raúl Gómez Muñoz
Pedro Leonel Olaya Trejos

Socio Formador

Casa Monarca

Instituto Tecnológico y de Estudios Superiores de Monterrey
Escuela de Ingeniería y Ciencias
Ingeniería en Ciencia de Datos y Matemáticas

11 de Junio del 2026

0.1. Resumen ejecutivo

Casa Monarca, Ayuda Humanitaria al Migrante, requería resolver la falta de un sistema centralizado y seguro para gestionar los expedientes de las personas que atiende y canalizarlos de forma controlada entre sus distintos niveles operativos. El manejo previo, basado en herramientas dispersas, dificultaba la trazabilidad de cada caso, exponía datos personales sensibles y no garantizaba que únicamente personal autorizado ejecutara acciones críticas como la validación o el cierre de un expediente.

El objetivo inicial de esta primera etapa fue construir un *gestor de identidades* y de expedientes que combinara control de acceso por roles, auditoría completa y una base sólida de criptografía aplicada. Se desarrolló una aplicación web en Flask que implementa un flujo de canalización de cuatro niveles (Usuario, Operativo, Coordinador y Administrador), autenticación reforzada con hashing Argon2id y verificación basada en infraestructura de clave pública (PKI X.509) y passkeys (WebAuthn) para los roles críticos, además de cifrado a nivel de campo de los datos sensibles con un esquema simétrico autenticado (Fernet).

El resultado logrado es una plataforma funcional que cubre el ciclo de vida completo de un expediente con trazabilidad de extremo a extremo: cada acción queda registrada en una bitácora de auditoría con usuario, rol y marca de tiempo. El impacto principal es la sustitución de un proceso manual y poco seguro por uno digital, controlado y verificable, que protege la información de una población vulnerable y reduce el riesgo de acceso indebido. El estado actual del sistema es de *piloto funcional*, validado mediante una suite de pruebas automatizadas y listo para un endurecimiento de despliegue previo a producción.

0.2. Objetivos vs. resultados

Los objetivos planteados al inicio de la etapa se cumplieron en su mayoría, y varios se ampliaron al detectarse oportunidades de reforzar la seguridad. La Tabla 1 resume la correspondencia entre lo propuesto y lo entregado.

Objetivo inicial	Estado	Resultado
Control de acceso por roles	Cumplido	Cuatro roles con permisos diferenciados y flujo de estados controlado.
Autenticación segura	Superado	Argon2id, bloqueo por intentos y verificación HIBP de contraseñas.
Auditoría de acciones	Cumplido	Bitácora por evento crítico con actor, rol y fecha.
Protección de datos sensibles	Superado	Cifrado de campo con Fernet e inventario y rotación de llaves.
Verificación de acciones críticas	Superado	PKI X.509 y passkeys (WebAuthn) con desafío-respuesta.

Cuadro 1: Objetivos iniciales frente a resultados de la Etapa 1.

Qué se cumplió. Se entregó el control de acceso por roles, el flujo completo de expedientes (*borrador* → *en revisión* → *validado* → *cerrado*), la bitácora de auditoría, la protección CSRF, el rate-limiting de inicio de sesión y los respaldos cifrados.

Qué se modificó o adaptó. El alcance original contemplaba únicamente firma de acciones mediante certificados X.509. Durante el desarrollo se incorporó además un mecanismo de passkeys (WebAuthn) más usable y resistente a *phishing*, planificándose la migración del firmado legacy hacia este nuevo flujo. Asimismo, la atención de derechos ARCO evolucionó de un esquema exclusivo de administrador a un flujo de aprobación multinivel.

Pendientes para siguientes versiones. Quedan por automatizar la emisión y el retiro de llaves de cifrado, completar la migración del firmado legacy a passkeys y trasladar el material criptográfico a un KMS/HSM en producción.

0.3. Solución implementada

Qué hace la aplicación. Casa Monarca es una aplicación web que permite registrar expedientes (encuestas/casos), canalizarlos a través de los niveles operativos y resguardar la información personal mediante cifrado. Un usuario inicia un expediente y lo canaliza; el personal operativo lo revisa y lo eleva; el coordinador lo valida y, finalmente, el administrador lo cierra. Cada transición está gobernada por reglas de permiso y, para los roles críticos (administrador y coordinador), exige una verificación criptográfica adicional mediante certificado o passkey antes de ejecutarse. La plataforma también gestiona las solicitudes ARCO (Acceso, Rectificación, Cancelación y Oposición) con un pipeline de aprobación que recorre los mismos niveles operativos.

Usuarios e impacto. Los usuarios son el personal de Casa Monarca organizado en cuatro perfiles. Los operativos y coordinadores ganan una herramienta única para dar seguimiento a los casos; los administradores obtienen control total con auditoría; y la organización en su conjunto reduce el riesgo de exposición de datos de los migrantes que atiende. El impacto se traduce en procesos más rápidos, verificables y conformes con buenas prácticas de protección de datos.

Alcance final. La solución cubre la gestión de usuarios y roles, el ciclo de vida del expediente, el cifrado de campo con gestión de llaves (inventario, métricas de latencia y re-cifrado controlado), la PKI de desarrollo con emisión/activación/revocación de certificados, las passkeys para verificación por acción, los respaldos cifrados y la bitácora de auditoría. La seguridad se sustenta en álgebra moderna aplicada: AES en el cifrado simétrico autenticado, HMAC-SHA256 para integridad, y criptografía de curva elíptica y RSA en los certificados X.509 y en WebAuthn.

0.4. Impacto de negocio

El principal valor para Casa Monarca es operativo y reputacional más que monetario: se protege a una población vulnerable y se reduce la responsabilidad asociada al manejo de datos personales. Aun así, el cambio genera beneficios medibles que se resumen en la Tabla 2.

Indicador	Antes	Después
Trazabilidad de acciones	Parcial o inexistente	Bitácora por acción crítica
Acceso a datos sensibles	Archivos en claro	Cifrado de campo (Fernet)
Verificación de roles críticos	Solo contraseña	Certificado X.509 / passkey
Recuperación ante incidentes	Respaldo manual	Respaldo cifrado y restaurable

Cuadro 2: Comparativo de la operación antes y después de la Etapa 1.

Ahorro y productividad. La centralización elimina la doble captura y la búsqueda manual de casos, lo que ahorra tiempo del personal operativo y reduce los errores de canalización. **Reducción de riesgos.** El cifrado de campo y la verificación criptográfica de acciones críticas disminuyen la probabilidad y el impacto de una fuga de datos, mientras que la bitácora habilita la detección y la rendición de cuentas. En conjunto, el sistema convierte un riesgo latente de cumplimiento en un proceso auditable.

0.5. Lecciones y hallazgos

Qué funcionó bien. El uso de estándares maduros (Argon2id, Fernet, X.509, WebAuthn) permitió alcanzar un nivel de seguridad alto sin reinventar primitivas criptográficas. El patrón de migración incremental del esquema de base de datos hizo posible evolucionar el modelo sin romper instalaciones existentes. La verificación por desafío–respuesta resultó natural de integrar en el flujo de acciones críticas.

Qué se puede mejorar. La concentración de la lógica en un único archivo backend facilitó el prototipado, pero dificulta el mantenimiento a largo plazo; conviene modularizar. La gestión de llaves todavía depende de pasos manuales que deben automatizarse, y el contador de bloqueo de inicio de sesión, basado en la

propia base de datos, debería migrar a un almacén en memoria para escalar.

Riesgos detectados. El material criptográfico (llave Fernet, claves de la CA) reside en archivos locales, adecuado para desarrollo pero insuficiente para producción, donde debe custodiarse en un KMS/HSM. La latencia del cifrado sobre volúmenes grandes debe vigilarse, y la coexistencia temporal de firmado legacy y passkeys requiere control para evitar caminos de verificación inconsistentes.

0.6. Estado actual y próximos pasos

Estado. El sistema se encuentra en estado de *piloto funcional*: todas las capacidades descritas operan localmente y están respaldadas por una suite de pruebas automatizadas que cubre seguridad de contraseñas, flujo de canalización, auditoría de cifrado, integración ARCO y vinculación/revocación de passkeys y certificados.

Recomendaciones.

- **Mejoras:** modularizar el backend, automatizar el ciclo de vida de llaves (generación, activación y retiro) y completar la migración del firmado legacy a passkeys.
- **Nuevas funcionalidades:** tablero de reportes y analítica, notificaciones de seguimiento e integración con un directorio corporativo (LDAP/AD) para inicio de sesión único.
- **Escalabilidad:** despliegue tras un proxy HTTPS, custodia de secretos en KMS/HSM, contadores de sesión en un almacén en memoria (Redis) y empaquetado en contenedores para escalado horizontal.

Referencias

- National Institute of Standards and Technology. (2020). *Recommendation for key management: Part 1 — General (NIST SP 800-57 Part 1 Rev. 5)*. U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-57pt1r5>
- Biryukov, A., Dinu, D., & Khovratovich, D. (2016). Argon2: New generation of memory-hard functions for password hashing and other applications. *2016 IEEE European Symposium on Security and Privacy (EuroS&P)*, 292–302. <https://doi.org/10.1109/EuroSP.2016.31>
- World Wide Web Consortium. (2021). *Web Authentication: An API for accessing public key credentials (Level 2)*. W3C Recommendation. <https://www.w3.org/TR/webauthn-2/>
- Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., & Polk, W. (2008). *Internet X.509 public key infrastructure certificate and CRL profile (RFC 5280)*. Internet Engineering Task Force. <https://doi.org/10.17487/RFC5280>
- Pallets Projects. (2024). *Flask documentation*. <https://flask.palletsprojects.com/>